

Web Application Reconnaissance

Prepared by: Hilmi Nasir

Date: 13th March 2026

1. Introduction

Web reconnaissance is the first stage of penetration testing where an attacker or security analyst gathers information about a target website. The purpose of this project is to identify technologies used by a web application, discover hidden directories, analyze HTTP headers, and detect potential security weaknesses.

The tools used in this project include:

- WhatWeb
- Gobuster
- Nikto
- Curl
- Dig
- Sublist3r

The target website used for this lab is **example.com**, which is a safe domain intended for testing and educational purposes.

2. Objectives

The objectives of this project are:

- Identify technologies used by a target website
- Discover hidden directories or files
- Analyze HTTP headers and server behaviour
- Investigate DNS records and infrastructure
- Perform basic vulnerability scanning
- Understand the reconnaissance process in web security testing

3. Tools Used

Tool	Purpose
WhatWeb	Identifies web technologies used by a website
Gobuster	Performs directory brute forcing
Nikto	Scans for web server vulnerabilities
Curl	Retrieves HTTP headers
Dig	Performs DNS queries
Sublist3r	Finds subdomains of a target domain

4. Methodology

The reconnaissance process was conducted in several steps using Kali Linux tools.

4.1 Technology Fingerprinting

Tool used: **WhatWeb**

Command executed: `whatweb https://example.com`

Purpose:

This command identifies technologies used by the target website such as web servers, frameworks, and content management systems.

Observation:

The scan revealed that the website is protected by **Cloudflare** and uses standard HTML5 technology.

Security Insight:

Cloudflare acts as a reverse proxy which helps protect the origin server from direct attacks.

```
kali@kali:~$ whatweb https://example.com
https://example.com [200 OK] Allow[GET, HEAD], Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], IP[104.18.26.120], Title[Example Domain], UncommonHeaders[cf-cache-status,cf-ray]
```

4.2 Directory Enumeration

Tool used: **Gobuster**

Command executed:

`gobuster dir -u https://example.com -w /usr/share/wordlists/dirb/common.txt`

Purpose:

Gobuster attempts to discover hidden directories or files by brute forcing common directory names.

Observation:

No hidden directories were discovered during the scan.

Security Insight:

The website does not expose common directories from the wordlist used.

```
(kali@kali)-[~]
$ gobuster dir -u https://example.com -w /usr/share/wordlists/dirb/common.txt

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: https://example.com
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

4.3 Web Vulnerability Scanning

Tool used: **Nikto**

Command executed:

```
nikto -h https://example.com
```

Purpose:

Nikto scans web servers for known vulnerabilities and misconfigurations.

Observation:

Nikto reported the following security header issues:

- Missing **X-Frame-Options**
- Missing **Strict-Transport-Security**
- Missing **X-Content-Type-Options**

Security Insight:

The absence of these headers may expose users to attacks such as clickjacking or MIME type sniffing.

```

(kali@kali)~$ nikto -h https://example.com
Nikto v2.3.0

+ Multiple IPs Found: 104.18.27.120, 104.18.26.120, 2606:4700::6812:1a78, 2606:4700::6812:1b78
+ Target IP: 104.18.27.120
+ Target Hostname: example.com
+ Target Port: 443

+ SSL Info: Subject: /CN=example.com
            Ciphers: TLS_AES_256_GCM_SHA384
            Issuer: /C=US/O=SSL Corporation/CN=Cloudflare TLS Issuing ECC CA 3
+ Start Time: 2026-03-12 23:01:39 (GMT-4)

+ Server: cloudflare
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't connect: SSL negotiation failed: error:0A000410:SSL routines::ssl/tls alert handshake failure at /var/lib/nikto/plugins/L
02.pm line 5254.
+ at /var/lib/nikto/plugins/L02.pm line 5254.
+ at /var/lib/nikto/plugins/L02.pm line 5254.
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time: 2026-03-12 23:05:59 (GMT-4) (260 seconds)

+ 1 host(s) tested

(kali@kali)~$

```

4.4 HTTP Header Analysis

Tool used: **Curl**

Command executed: `curl -I https://example.com`

Observation: The server returned the following headers:

HTTP/2 200

content-type: text/html

server: cloudflare

allow: GET, HEAD

cf-cache-status: HIT

Explanation:

- **HTTP/2 200** indicates a successful response.
- **server: cloudflare** confirms the website is protected by Cloudflare.
- **allow: GET, HEAD** shows only safe HTTP methods are allowed.

Security Insight:

No dangerous HTTP methods such as PUT or DELETE were detected.

```

(kali@kali)~$ curl -I https://example.com
HTTP/2 200
date: Fri, 13 Mar 2026 03:08:45 GMT
content-type: text/html
cf-ray: 9db7d600ff6a7362-NRT
last-modified: Wed, 11 Mar 2026 19:08:51 GMT
allow: GET, HEAD
accept-ranges: bytes
age: 14288
cf-cache-status: HIT
server: cloudflare

```

4.5 DNS Investigation

Tool used: **Dig**

Command executed: dig example.com

Observation: The domain resolves to two IP addresses:

104.18.27.120

104.18.26.120

Explanation:

Multiple IP addresses indicate load balancing via Cloudflare.

Security Insight:

Load balancing improves availability and protects against certain types of network attacks.

```
(kali㉿kali)-[~]  
$ dig example.com  
  
; <<>> DiG 9.20.15-2-Debian <<>> example.com  
;; global options: +cmd  
;; Got answer:  
;; —>HEADER<— opcode: QUERY, status: NOERROR, id: 20917  
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; udp: 512  
;; QUESTION SECTION:  
;example.com.                IN      A  
  
;; ANSWER SECTION:  
example.com.                252     IN      A      104.18.27.120  
example.com.                252     IN      A      104.18.26.120  
  
;; Query time: 12 msec  
;; SERVER: 192.168.0.1#53(192.168.0.1) (UDP)  
;; WHEN: Fri Mar 13 00:09:07 EDT 2026  
;; MSG SIZE  rcvd: 72
```

4.6 Subdomain Enumeration

Tool used: **Sublist3r**

Command executed: `sublist3r -d example.com`

Purpose: Sublist3r searches for publicly available subdomains related to the target domain.

Observation: No subdomains were discovered during the scan.

Security Insight: The target domain appears to have limited exposed subdomain infrastructure.

```
(kali㉿kali)-[~]
$ sublist3r -d example.com
Command 'sublist3r' not found, but can be installed with:
sudo apt install sublist3r
Do you want to install it? (N/y)y
sudo apt install sublist3r
[sudo] password for kali:
Installing:
  sublist3r

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1742
  Download size: 621 kB
  Space needed: 1,947 kB / 63.0 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 sublist3r all 1.1-5 [621 kB]
Fetched 621 kB in 20s (30.7 kB/s)
Selecting previously unselected package sublist3r.
(Reading database ... 422191 files and directories currently installed.)
Preparing to unpack .../sublist3r_1.1-5_all.deb ...
Unpacking sublist3r (1.1-5) ...
Setting up sublist3r (1.1-5) ...
Processing triggers for kali-menu (2025.4.3) ...
Processing triggers for man-db (2.13.1-1) ...
```

5. Findings and Analysis

The reconnaissance process revealed that the target website is protected behind Cloudflare infrastructure.

Key observations include:

- The website uses Cloudflare CDN protection
- Only safe HTTP methods (GET, HEAD) are enabled
- No common directories were discovered
- Some recommended security headers were missing

These findings indicate that while the website is moderately secured, certain security headers could be implemented to improve protection against client-side attacks.

6. Conclusion

This project demonstrated the web reconnaissance phase of a penetration test using multiple security tools available in Kali Linux.

The reconnaissance process successfully identified the technologies used by the target website, analyzed its DNS infrastructure, and scanned for potential vulnerabilities.

Although no critical vulnerabilities were discovered, the analysis highlighted the importance of proper security header configuration and the role of Cloudflare in protecting web infrastructure.

This project provided practical experience with common web security tools and improved understanding of the reconnaissance phase in cybersecurity assessments.